Vulnerability Assessment Report

Prepared By

Oscar Alotchéwou ALIDJINOU

oscaralidjinou27@gmail.com

Target Website

testphp.vulnweb.com

Summary.

1. **INTRODUCTION**
2. **SCOPE ASSESSMENT**
3. **METHODOLOGY**
4. **TECHNICAL FINDINGS & RECOMMENDATION**
5. **RISK CLASSIFICATION SUMMARY**
6. **CONCLUSION**

Introduction.

This report presents the findings of a Vulnerability Assessment conducted on the target website. The objective of this assessment was to identify security weaknesses, misconfigurations, and potential entry points that could be exploited by malicious actors.

Through a combination of automated scanning and manual testing techniques, several vulnerabilities were discovered, ranging from information disclosure to critical access control issues. This document outlines the identified vulnerabilities, their potential impact, and recommended remediation measures to enhance the overall security posture of the application.

SCOPE ASSESSMENT.

This report documents the penetration test conducted on the website http://testphp.vulnweb.com from February 16, 2026, to February 21, 2026. This test was carried out within a legal framework and adheres to the ethical principles of hacking. No vulnerabilities were exploited.

The test focused instead on Passive Scanning, Header Verification, and Configuration Analysis. No login bypass, brute force, DoS, or any methods of taking control of the website were performed.

Methodology.

WEBSITE SELECTION

For this test, I chosse
http://testphp.vulnweb.com because it is a public website
that is intentionnally
vulnerable.

READ-ONLY ANALYSIS

The vulnerability analysis of this site is not followed by any exploit or attack. The objective is to find vulnerabilities, classify them according to their risk level, and propose solutions

TOOLS USED

To carry out this mission, here are the tools I used:

- Nmap: port scanning, service detection,etc.
- OWASP ZAP: passive scan
- Browser DevTools

Technical Findings.

FINDING 1

HTTP PROTOCOL INSTEAD OF HTTPS

DESCRIPTION

The "HTTP" protocol is used for data transfer between the browser and

the web server. With HTTP, data is sent in clear text, without encryption. This poses a security risk. An attacker on the same network could intercept the data. Passwords, for example, could be visible.
In contrast, with HTTPS, data is encrypted and protected against interception.

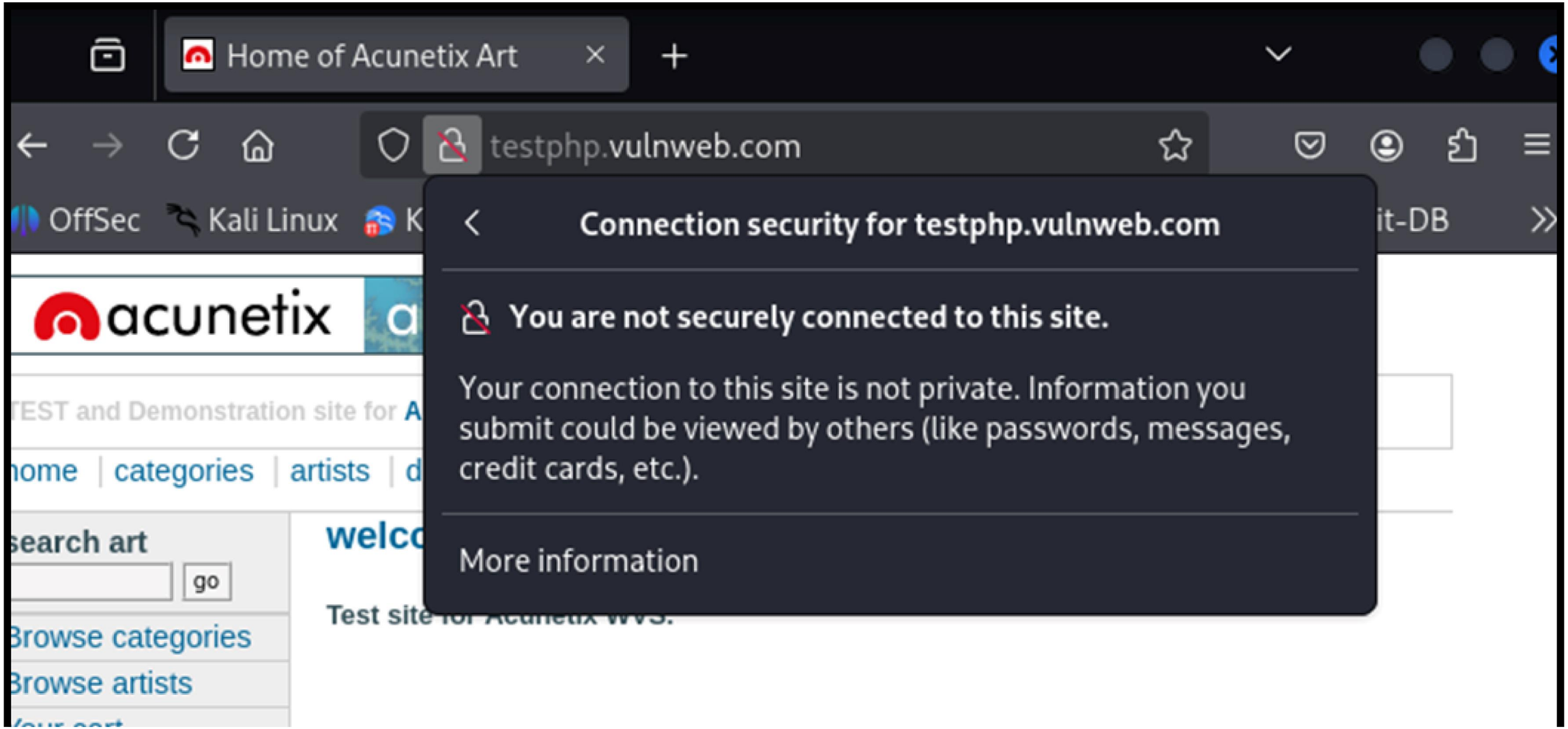
RISK

HIGH

REMEDIATION

Change the http into htttps for a secure website.

EVIDENCE


Home of Acunetix Art
testphp.vulnweb.com
OffSec
Kali Linux
Connection security for testphp.vulnweb.com
You are not securely connected to this site.
Your connection to this site is not private. Information you submit could be viewed by others (like passwords, messages, credit cards, etc.).
More information
acunetix
TEST and Demonstration site for A
home | categories | artists | d
search art
go
Browse categories
Browse artists

RISK

FINDING 2

EXPOSED CREDENTIALS

HIGH

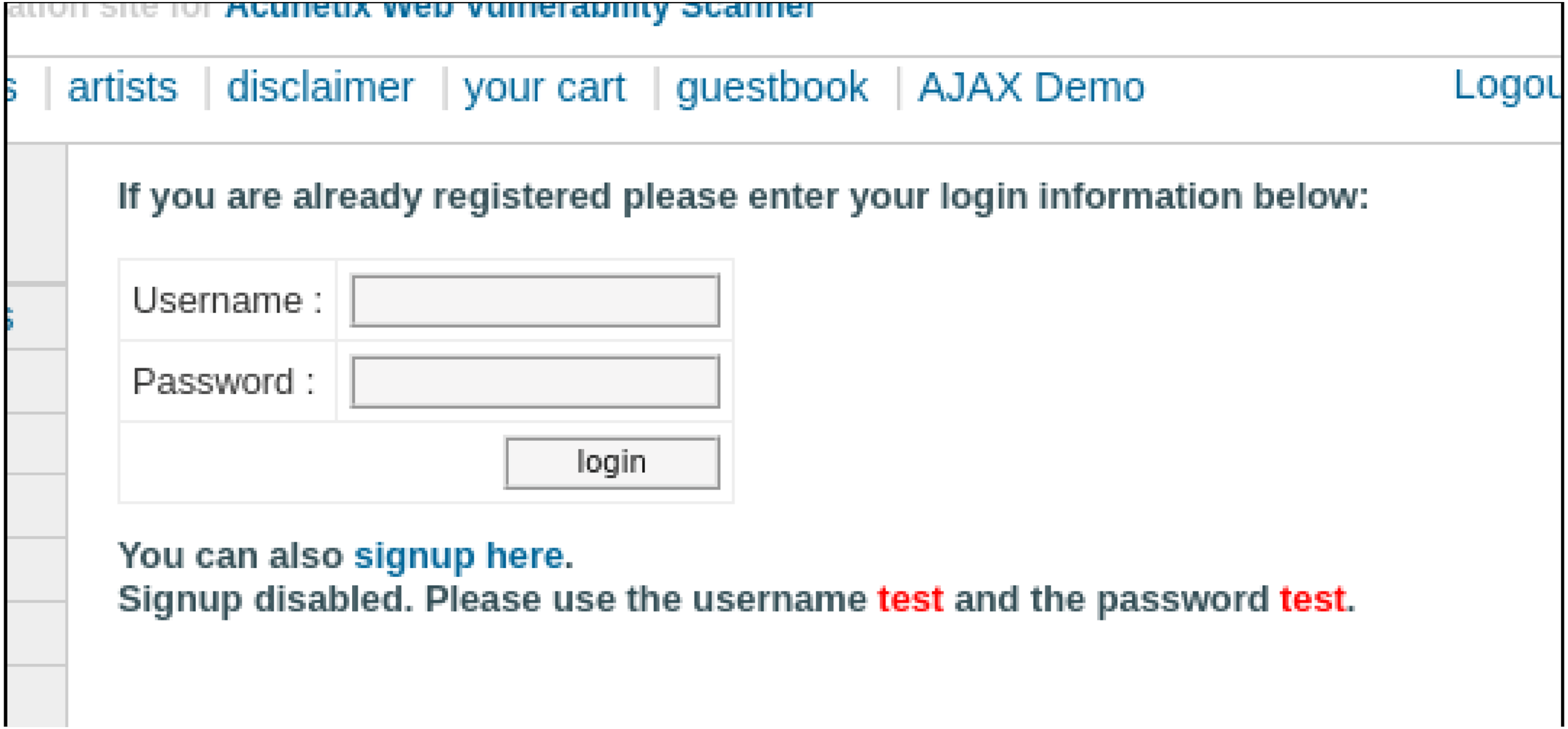
DESCRIPTION

The credentials (username and password) that the user uses to log in to the site are displayed in clear text on the site.

REMEDIATION

I recommend that the password be removed from the site and stored encrypted in a database.

EVIDENCE


artists
disclaimer
your cart
guestbook
AJAX Demo
Logou
If you are already registered please enter your login information below:
Username :
Password :
login
You can also signup here.
Signup disabled. Please use the username test and the password test.

FINDING 3

VERY WEAK PASSWORD

RISK

HIGH

DESCRIPTION

The password "test" used to log in is very short and very

REMEDIATION

I recommend that the site require simple. users to have a password of at least 8 characters with the following constraints:

- At least one uppercase or lowercase letter.
- At least one number. At least one special
- character.

FINDING 4	TOOL USED	RISK
CONTENT SECURITY POLICY (CSP) HEADER NOT SET	OWASP ZAP	MEDIUM
DESCRIPTION		**REMEDIATION**
Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames,		fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files Ensure that your web server, application server, load balancer, etc. is configured to set the ContentSecurity-Policy header.
MISSING ANTI-CLICKJACKING HEADER		MEDIUM

FINDING 5

TOOL USED

OWASP ZAP

RISK

DESCRIPTION

The response does not protect against 'ClickJacking' attacks. Modern Web browsers support the Content-Security-Policy with 'frame- ancestors' directive or X-Frame-Options. Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive

IN PAGE BANNER

INFORMATION LEAK

REMEDIATION

It should include either Content-Security-Policy and X-Frameancestors' directive or X-Frame-Options. Options

LOW

FINDING 6

TOOL USED

OWASP ZAP

RISK

DESCRIPTION

The server returned a version banner string in the response leaks may allow attackers to information leaks. For example: further target specific issues impacting the product and Under Tomcat this is done via the "server" version in use.

REMEDIATION

Configure the server to prevent such content. Such information directive and implementation of custom error pages.

Under Apache this is done via the "ServerSignature" and "ServerTokens" directives

FINDING 7	TOOL USED	RISK
SERVER LEAKS INFORMATION VIA "X-POWERED-BY" HTTP RESPONSE HEADER FIELD(S)	OWASP ZAP	LOW

DESCRIPTION

The web/application server leaks information through one or more "X-Powered-By" HTTP response headers. Access to server, load balancer, etc. is configured to this information can facilitate attackers in identifying which suppress "X-Powered-By" headers.

REMEDIATION

Ensure that your web server, application server, load balancer, etc. is configured to suppress "X-Powered-By" headers.

FINDING 8	TOOL USED	RISK
other frameworks/components your web application depends on, and the vulnerabilities of such components may then be exploited.		
SERVER LEAKS VERSION INFORMATION VIA "SERVER" HTTP RESPONSE HEADER FIELD	OWASP ZAP	LOW

FINDING 9 **TOOL USED** **RISK**

DESCRIPTION **REMEDIATION**

The web/application server is leaking version information via Ensure that your web server, application the "Server" HTTP response header. Access to such server, load balancer, etc. is configured to information may facilitate attackers identifying other suppress the "Server" header or provide vulnerabilities your web/application server is subject to. generic details.

The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.

FINDING 10	TOOL USED	RISK
X-CONTENT-TYPE-OPTIONS HEADER MISSING	OWASP ZAP	LOW
DESCRIPTION		**REMEDIATION**
AUTHENTICATION REQUEST IDENTIFIED	OWASP ZAP	INFORMATIONAL
DESCRIPTION		**REMEDIATION**
Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform		The given request has been identified as an authentication request. The 'Other Info' field contains a set of key=value lines which identify any relevant fields. If the request is in a context which has an Authentication

FINDING 11	TOOL USED	RISK
Method set to "AutoDetect" then this rule will change the authentication to match the request identified. This is an informational alert rather than a vulnerability and so there is nothing to fix.		

	TOOL USED	RISK
FINDING 11		
CHARSET MISMATCH (HEADER VERSUS META CONTENT-TYPE CHARSET)	OWASP ZAP	INFORMATIONAL

DESCRIPTION

This check identifies responses where the HTTP ContentType header declares a charset different from the charset defined by the body of the HTML or XML. When there's a charset mismatch between the HTTP header and content body Web browsers can be forced into an undesirable content-sniffing mode to determine the content's correct character set.

REMEDIATION

Forcer UTF-8 pour tous les contenus texte dans l'en-tête HTTP et dans les meta-balises, ou pour coder les déclarations XML.

FINDING 12	
USER CONTROLLABLE HTML ELEMENT	OWASP ZAP

EVIDENCE

ATTRIBUTE (POTENTIAL XSS) **DESCRIPTION**

This check looks at user-supplied input in query string parameters and POST data to identify where certain HTML attribute values might be controlled. This provides hot-spot detection for XSS (cross-site scripting) that will require further review by a security analyst to determine exploitability.

INFORMATIONAL

REMEDIATION

Validate all input and sanitize output it before writing to any HTML attributes.

TOOL USED **RISK**

Démarrage rapide | Requête | Réponse | Requêteur

Sites

En-tête: Raw View | Corps: Raw View

```
HTTP/1.1 200 OK
Server: nginx/1.19.0
Date: Fri, 20 Feb 2026 17:35:14 GMT
Content-Type: text/html; charset=UTF-8
Connection: keep-alive
```

```
  if (init==true) with (navigator) {if ((appName=="Netscape")&&(parseInt(appVersion)==4)) {
    document.MM_pgW=innerWidth; document.MM_pgH=innerHeight; onresize=MM_reloadPage; }}
  else if (innerWidth!=document.MM_pgW || innerHeight!=document.MM_pgH) location.reload();
}
MM_reloadPage(true);
```

Historique | Rechercher | Alertes | Output | Robot d'indexation | AJAX Spider

- Absence de Jetons Anti-CSRF (Systemic)
- Content Security Policy (CSP) Header Not Set
- Mauvaise configuration inter-domaines
- Missing Anti-clickjacking Header (Systemic)
- In Page Banner Information Leak (3)
- Server Leaks Information via "X-Powered-By"
- Server Leaks Version Information via "Server"

Id WASC : 15
Source : Scan passif (10038 - Content Security Policy (CSP) Header Not Set)
Alert Reference: 10038-1
Input Vector:

Déscription:

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or

Autres informations :

Using the "Nmap" tool to scan the site, it can be noted that I recommend that the paths to port 80 is open, and after enumeration, a major vulnerability /admin/ and /CVS/ be hidden and that is discovered. access be controlled.
The admin page can be accessed simply by entering its path in the

FINDING 13	TOOL USED	RISK
PATHS TO IMPORTANT FILES EXPOSED	NMAP	HIGH

DESCRIPTION

browser. This directly provides access to the database. Access to "CVS" which contains log history and sensitive information.

REMEDIATION

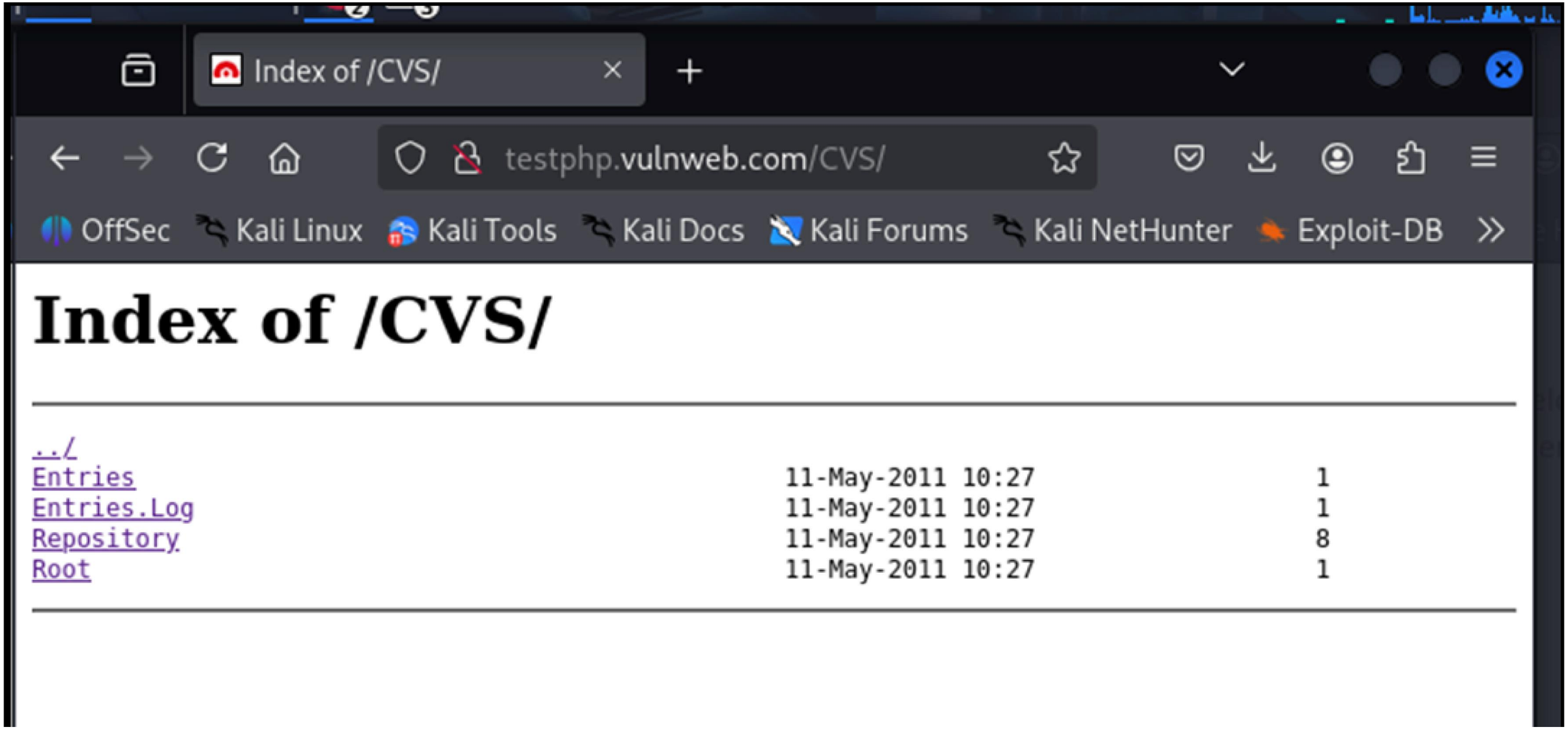
EVIDENCE

```
┌──(osnux㉿Osnux)-[~]
└─$ nmap testphp.vulnweb.com
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-20 23:50 CET
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.023s latency).
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.co
m
Not shown: 999 filtered tcp ports (no-response)
PORT   STATE SERVICE
80/tcp open  http

Nmap done: 1 IP address (1 host up) scanned in 17.56 seconds
```

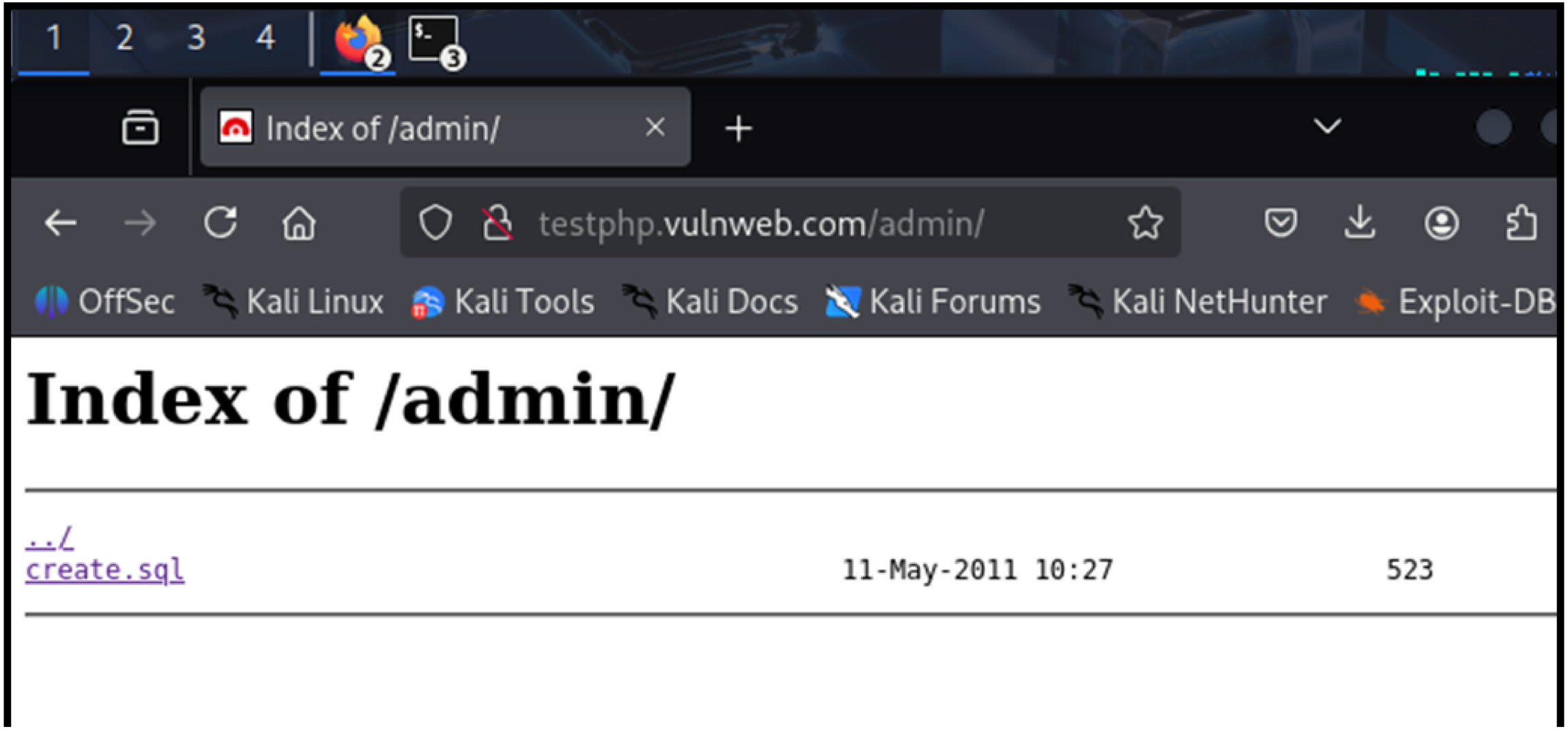
EVIDENCE

```
┌──(osnux㉿Osnux)-[~]
└─$ nmap -p 80 --script http-enum testphp.vulnweb.com
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-20 23:52 CET
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.046s latency).
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com

PORT   STATE SERVICE
80/tcp open  http
| http-enum:
|   /admin/: Possible admin folder
|   /login.php: Possible admin folder
|   /clientaccesspolicy.xml: Microsoft Silverlight crossdomain policy
|   /crossdomain.xml: Adobe Flash crossdomain policy
|_  /CVS/: Potentially interesting folder w/ directory listing

Nmap done: 1 IP address (1 host up) scanned in 206.13 seconds
```

EVIDENCE


Index of /CVS/
testphp.vulnweb.com/CVS/
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Index of /CVS/
../
Entries 11-May-2011 10:27 1
Entries.Log 11-May-2011 10:27 1
Repository 11-May-2011 10:27 8
Root 11-May-2011 10:27 1

EVIDENCE


1 2 3 4
Index of /admin/
testphp.vulnweb.com/admin/
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Index of /admin/
../
create.sql 11-May-2011 10:27 523

Risk Classification Summary.

	VULNERABILITY	RISI
1	rotocol Instead of HTTPS	HIGH

2	[illegible]	HIGH
3	[illegible]	[illegible]

4	Content Security Policy (CSP) Header Not Set	MEDIU

	VULNERABILITY	**RISI**
5	[redacted]-clickjacking Header	MEDIU

6	[illegible]	LOW

7	[redacted] TP Response	LOW

8	Server Leaks Version Information via "Server" HTTP Response Header Field	LOW
9	X-Content-Type-Options Header Missing	

10	Authentication Request Identified	INFORMAT
	VULNERABILITY	**RISI**
11	Versus Meta Content-Type Charset)	INFORMAT

12	[redacted]ributte (Potential XSS)	INFOR[redacted]
13	Paths to important files exposed	HIGH

4 HIGH RISK

2 MEDIUM RISK

4 LOW RISK

3 HIGH RISK

Conclusion.

The Vulnerability Assessment revealed several security flaws that pose significant risks to the confidentiality, integrity, and availability of the application and its data.

The identified issues, including exposed credentials, weak password policies, information leakage, missing CSRF protections, and unprotected sensitive directories, require immediate attention.

By implementing the recommended remediations, such as securing access to sensitive paths, enforcing strong password policies, and removing information-disclosing HTTP headers, the organization can significantly reduce the attack surface and strengthen its defenses against potential cyber threats.